



PROJECT REPORT & COMPETITION SUBMISSION

MediFlow

A privacy-first agentic AI for clinic care
— what was built and how it was
secured.

SUBMITTED TO

Agentic AI 2026 (EAI) — Ministry of Transport, Communications &
Information Technology, Oman.

0

patient names ever sent to the
AI

100%

of bookings need human
approval

25

tracked security migrations

PROJECT REPORT & COMPETITION SUBMISSION

Secure Digital Transformation

MediFlow — a patient system rebuilt security-first.

SUBMITTED TO

Cybersecurity Excellence Award (CEAE) — Ministry of Health, Oman.
Category · Best Secure Digital Transformation Project

25/25

tables protected by row-level security

AES

civil ID encrypted (pgcrypto + Vault)

MFA

on sensitive actions + audit + alerts

Contents

1	Executive summary — what MediFlow is	8	Table 3 · Advantages, disadvantages & fixes
2	What we fixed & built (work log)	9	Table 4 · Honest score & maturity estimate
3	How the AI works safely (diagram)	10	Security architecture (diagram)
4	Human-in-the-loop, no-shows & waitlist	11	Award mapping · 8 domains
5	The evaluators' feedback — answered	12	Risk register
6	Table 1 · Where everything lives in Supabase	13	Database evidence (live)
7	Table 2 · Cyber-attacks defended	14	What connects to what & next steps

Executive summary

MediFlow is the patient-facing digital + AI system for MCC Clinic — online booking, an AI assistant, staff dashboards, QR check-in and automated notifications. It was rebuilt **security-first** so the AI can help without ever touching patient identity, and so no appointment is confirmed without a human.

For patients

- Book online and track status (awaiting approval → confirmed).
- Chat about symptoms — by pseudonymous ID, never by name.
- QR check-in carrying only a booking reference.
- See exactly what the AI receives about them.

For the clinic

- Approve or reject every appointment before it is confirmed.
- Doctors see an AI visit summary — with no patient name.
- Cancelled slots auto-offered to waiting patients.
- Automatic email confirmations and security alerts.

Scope of this report: the database & application security layer — all applied to the live production database, verified, and version-controlled (25 migrations). Frontend, n8n and Gemini integration steps are listed in section 14.

What we fixed & built

The evaluation flagged that the AI and the doctor dashboard could see patient PII. That is closed, and a full set of safeguards was added.

Privacy & encryption

- Identity vault: name, age, gender, email, encrypted civil ID — isolated.
- Civil ID encrypted (pgcrypto) with a key held in Supabase Vault.
- Doctor dashboard made ID-only — no patient name, ever.
- AI agent walled off from all identity data.

Access control

- Row-level security on every table; nothing public.
- Role model: patient / doctor / reception / admin.
- Least-privilege AI database role.
- MFA required for civil-ID access and approvals.

Safe operations

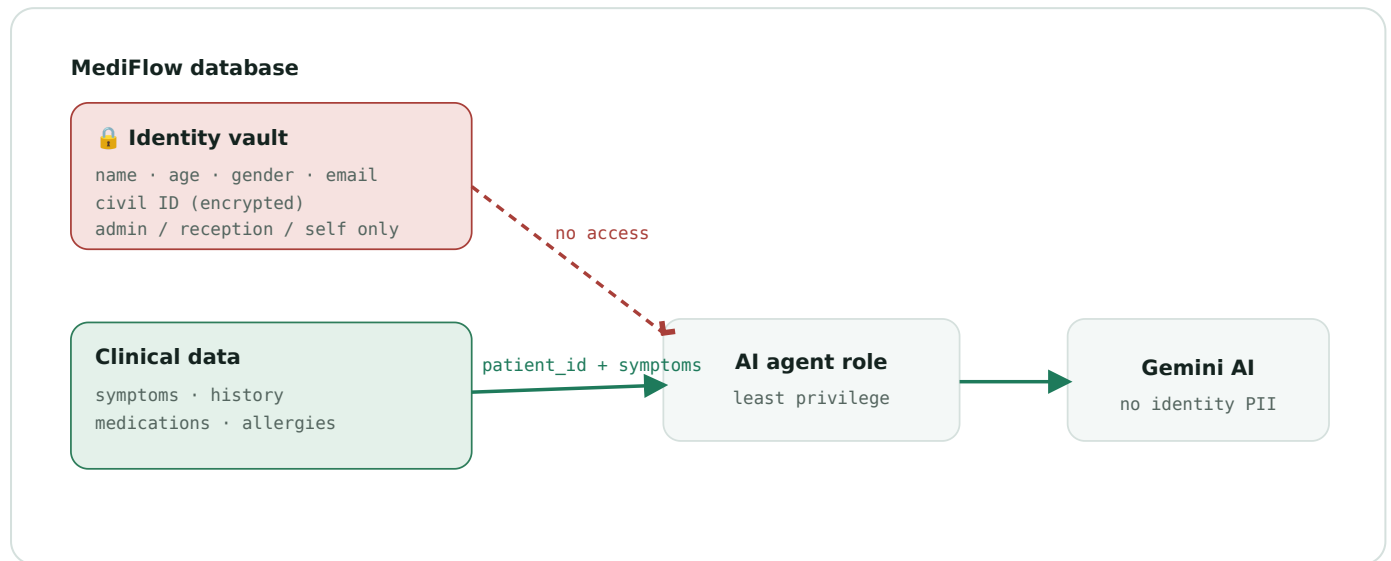
- Human-in-the-loop approval on every appointment.
- No-show handling (staff + automatic sweep).
- Cancellation waitlist that re-fills freed slots.
- Email confirmations via a secure outbox.

Governance

- Data-use consent record + patient privacy notice.
- Audit trail of sensitive actions + email alerts.
- Right-to-erasure, anti-abuse limit, transparency view.
- All changes tested (rolled-back) & version-controlled.

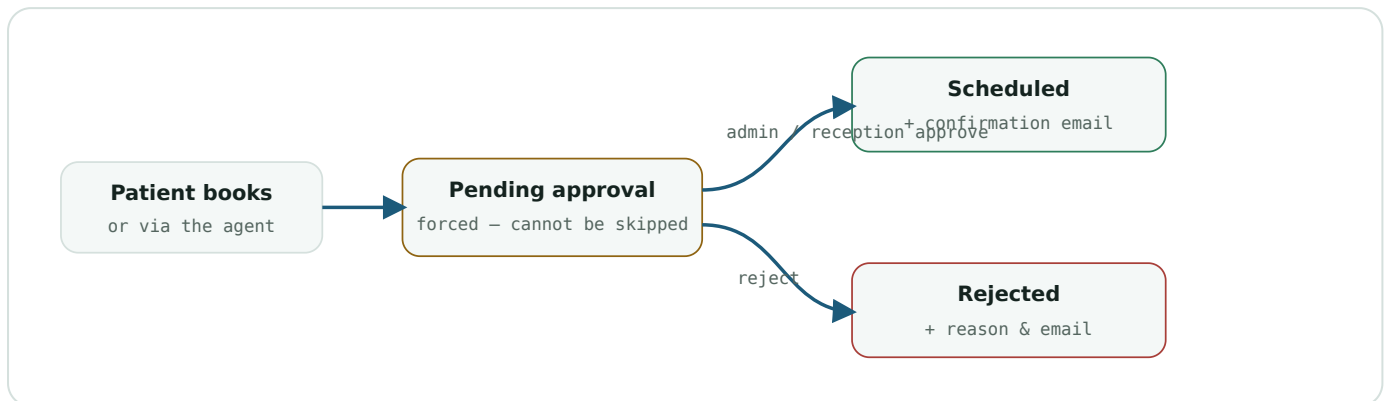
How the AI works safely

The AI agent is a separate database login whose entire world is a clinical view keyed by a pseudonymous ID. It cannot reach the identity vault.



Verified against the live database: the AI role **can** read the clinical view, **cannot** read the identity vault, and **cannot** decrypt a civil ID.

Human-in-the-loop, no-shows & waitlist



Every appointment starts in **Pending approval**, enforced in the database. Downstream: check-in → in-consultation → checked-out; automatic **no-show** 30 min after a missed start time.

Waitlist: when a patient cancels, the freed slot is auto-offered to the next opted-in patient with a later appointment — they choose "move up" or "keep", and the move still needs staff approval + email.

The evaluators' feedback — answered

RECOMMENDATION	WHAT WE DID	STATUS
Never send patient identity to the LLM; share symptoms only	Least-privilege AI role reads only ID + clinical; identity walled off.	Done
Show a clear data-use disclaimer	Consent record + privacy notice + AI-data transparency view.	Done
Human-in-the-loop before any appointment is finalised	Force-pending + admin/reception approve/reject + email.	Done
Define how no-shows are handled	Staff + automatic no-show; freed slots re-offered.	Done
Integrate with existing booking systems, don't replace	Clean API + email outbox make MediFlow integratable.	Enabled
Raise core value (voice intake, curated doctor list)	Product / UX roadmap — outside database scope.	Roadmap
Move beyond prompt engineering as data grows	Data / ML strategy — roadmap.	Roadmap

Where everything lives in Supabase

Every object built, and where to see it in the Supabase dashboard.

WHAT	NAME	WHERE IN SUPABASE
TABLES – TABLE EDITOR (PUBLIC SCHEMA)		
Identity vault (name/age/gender/email/enc. civil ID)	patients	Table Editor
Clinical data (AI source)	patient_clinical	Table Editor
AI visit summaries	visit_summaries	Table Editor
Email queue (approvals + alerts)	email_outbox	Table Editor
Appointments (+ approval / patient_ref / wants_earlier)	appointments	Table Editor
Cancellation waitlist offers	slot_offers	Table Editor
Data-use consent	patient_consents	Table Editor
Audit trail (admin-only)	audit_log	Table Editor
Settings (alert recipient)	app_settings	Table Editor
Full pre-change backup (18 tables)	backup_20260811	Table Editor → switch schema
DASHBOARD VIEWS – TABLE EDITOR (PUBLIC)		
Doctor (ID-only, no name)	dashboard_doctor_appointments / _patient_summary	Table Editor
Patient / Reception / Admin	dashboard_patient_appointments · _reception_queue · _admin_*	Table Editor
Approval queue	dashboard_pending_approvals	Table Editor
Waitlist (patient + staff)	dashboard_my_slot_offers · _slot_offers_pending	Table Editor
"What the AI sees about me"	dashboard_my_ai_data	Table Editor
Agent-only views (no PII)	agent.patient_clinical · agent.appointment_context	Table Editor → schema agent
FUNCTIONS – DATABASE → FUNCTIONS		
Approve / reject appointment	approve_appointment · reject_appointment	Database → Functions
Waitlist logic	respond_/approve_/reject_slot_offer · patient_set_wants_earlier	Database → Functions
Civil-ID (admin, MFA)	admin_get_/set_patient_civil_id	Database → Functions
Erasure / consent / no-show	admin_delete_patient_data · record_consent · auto_mark_no_shows	Database → Functions
Agent writes	agent.record_symptoms · agent.write_visit_summary	Database → Functions
ROLES, KEYS, JOBS & CONFIG		
AI login (least privilege)	mediflow_agent	Database → Roles

WHAT	NAME	WHERE IN SUPABASE
Civil-ID encryption key	civil_id_encryption_key	Project Settings → Vault
Access rules	RLS policies (all tables)	Database → Policies
Scheduled jobs	mediflow-auto-no-show · mediflow-expire-offers	select * from cron.job
Two-factor authentication	MFA (TOTP)	Authentication → Multi-Factor

Cyber-attacks defended

Each threat, a plain scenario, and the control that stops it.

ATTACK	SCENARIO	PROTECTION
AI / prompt-injection leak	"Tell me every patient's name" to the chatbot	The AI was never given names — it cannot leak them
Stolen AI credential	The AI's DB password leaks	Only clinical-by-ID; no names/email/civil ID
Broken access control (IDOR)	A patient tries to read another's record	RLS returns only their own rows
SQL injection	Malicious input via a form	Parameterized functions + RLS limit damage
Stolen database / backup	The whole DB is copied	Civil IDs encrypted; passwords bcrypt-hashed
Account takeover	A reused leaked password	MFA + bcrypt + rate limits
Privilege escalation	A doctor self-grants admin	Functions re-check role; role table locked
Over-privileged insider	A doctor browses identities	Doctors are ID-only — no name given
Anonymous scraping	A bot hits the API without login	Anonymous access returns zero rows
Fraudulent / auto bookings	A script creates a pre-confirmed appointment	Force-pending + no direct writes; only approval finalises
Unauthorized approval	A patient approves their own booking	Approve/reject gated to admin/reception only
Booking spam	A bot floods fake requests	Max 3 open requests + human review
Repudiation	Dispute over who confirmed	approved_by / rejected_by audit trail
Queue-jumping	Grabbing a freed slot not offered to you	Offers only to opted-in candidates; move needs approval
Stolen admin session	Hijacked admin tries to read civil IDs	MFA (AAL2) required for decrypt + approvals
Covert insider access	Staff quietly views a civil ID	audit_log + email alert on high-risk actions
Undisclosed AI use	Data shared with AI without awareness	patient_consent records the disclaimer acceptance

Advantages, disadvantages & fixes

AREA	ADVANTAGE	LIMITATION	HOW TO SOLVE
Data separation	PII can't leak via AI or doctor views	More objects to maintain	Docs kept current; train devs
Encryption (civil ID)	Stolen DB reveals no civil IDs	Admin/service-role can decrypt	MFA on admin; rotate key; limit admins
Least-privilege AI	Tiny blast radius if creds leak	Only real once n8n uses the role	Point n8n at the restricted role (priority)
RLS everywhere	Strong per-row protection	Slight query overhead	Already optimized; test on changes
MFA	Blocks account takeover	Blocks staff who haven't enrolled	Enrol MFA; relax for demo if needed
Passwords (bcrypt)	Industry standard	Leaked-password check needs Pro	Strong unique passwords; Pro later
Backups	Full snapshot exists	No auto point-in-time recovery (free)	Pro for PITR, or scheduled exports
Third-party AI	Only de-identified data sent	Health data still leaves to Google	Sign data terms; consider EU/self-host
Human-in-the-loop	No fake/auto bookings; full audit	Adds a manual step	Reception can approve; add auto-rules later
No-show handling	Defined + automatic; frees slots	Fixed 30-min grace	Tune grace/timezone in the sweep
Auditability	Sensitive actions + alerts tracked	No "who viewed" read-log yet	Add read-audit trigger later
Monitoring	Email alerts on high-risk actions	Depends on n8n Gmail running	Wire n8n; optional SIEM/webhook
Consent & transparency	Disclaimer recorded; patient can see AI data	Needs frontend to display	Show notice + transparency page

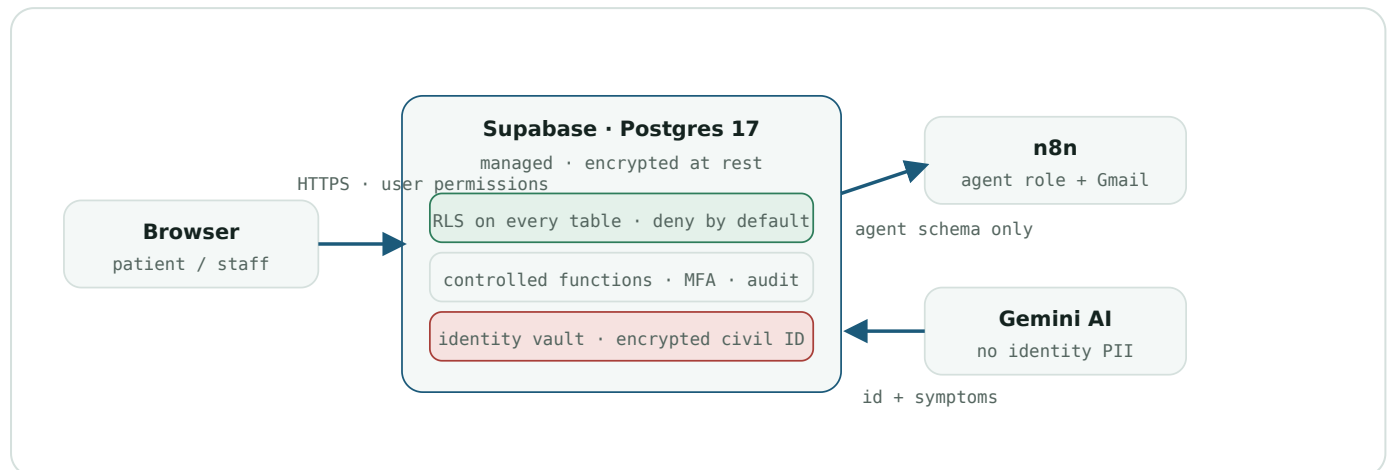
Honest score & maturity estimate

EAI feedback score was ~2.76/5 overall (privacy the weakest at 1.75/5). Effect of this work, by category — honest, not inflated.

EVALUATION CATEGORY (WEIGHT)	BEFORE	AFTER (THIS WORK)	WHAT STILL CAPS IT
AI Safety, Ethics & Oversight 15%	1.75	3.5 – 4.0	Wire AI role + show disclaimer
Technical Product 25%	2.5	3.0 – 3.25	"Prompted, not trained" (ML)
Impact & Business Viability 25%	3.5	3.6 – 3.8	Booking-system integration
Relevance & Innovation 20%	2.75	~3.0	Core value (voice/curated list)
Team & Future Plans 10%	2.75	~3.0	Roadmap
Pitch Quality 5%	3.5	~3.75	—

Overall: realistically ~2.76 → ~3.1-3.4 (about +0.4 to +0.6) once the AI role is wired, the disclaimer is shown, and the flows are demoed. The AI-Safety/Ethics axis — the weakest — is the biggest, near-certain gain. Roughly 30% of the score (integration + core value + ML) is product work the database cannot move.

Security architecture



Browser → Supabase over TLS with the user's own permissions. The AI reaches only the agent schema; the identity vault stays encrypted and isolated. n8n sends confirmation emails and security alerts.

Supabase (managed)

- Host & database patching
- Encryption at rest, backups, high availability

MediFlow project

- RLS, roles, civil-ID encryption, controlled functions
- MFA gating, audit, alerting — version-controlled

Cybersecurity Award — 8 domains

Assessed for the MediFlow project (Best Secure Digital Transformation Project).

DOMAIN (WEIGHT)	PROJECT EVIDENCE	MATURITY
Identity & Access 10%	RBAC, RLS, least-privilege AI role, MFA + AAL2	Excellence
Data Protection & Privacy 15%	Encrypted civil ID, identity isolation, minimization, consent	Excellence
Infrastructure & Systems 20%	Managed, encrypted, auto-patched Postgres; secure architecture	Mature
Governance & Policy 15%	Audit trail, role model, change control, docs	Mature
Innovation & Improvement 5%	Privacy-by-design AI boundary, human-in-the-loop, waitlist	Excellence
Compliance & Assurance 10%	Advisor-clean, audit evidence, tested migrations	Mature
Awareness & Training 10%	Privacy notice, consent, AI-data transparency	Mature
Monitoring & Incident Response 15%	Audit log + email alerts + IR runbook	Mature

Project maturity: solid **Mature (75-89)**, trending to Excellence once the frontend shows the notice/transparency page and the AI is wired.

Risk register

ASSET	THREAT	LEVEL	CONTROL IN PLACE
Patient database	SQL injection / data exposure	Medium	Parameterized functions, RLS, least privilege
AI agent	PII leak to the LLM	Medium	Restricted role, no PII in agent views, audit
Civil ID	Data-at-rest breach	Medium	pgcrypto + Vault, column lockdown, MFA decrypt
Staff account	Account takeover	Medium	MFA (AAL2), bcrypt, rate limits, RBAC
Booking integrity	Fraudulent / auto bookings	Medium	Human-in-the-loop, force-pending, audit
Patient portal / API	Broken access control (IDOR)	Medium	RLS row-scoping, role-scoped views
Email queue	PII leak via queue	Low	Service-role only; minimal content
Third parties	Processor / supply-chain risk	Medium	Data minimization to Gemini; DPAs = org action
Insider misuse	Staff snoops PII	Medium	RLS, MFA-gated civil ID, audit, doctor ID-only

Database evidence (live)

Pulled from the production database; each is verifiable in Supabase at the location noted.

25

tracked security migrations

25/25

tables with row-level security

57

controlled functions

2

scheduled security jobs

Where: Database → Migrations / Policies / Functions; select * from cron.job.

The AI agent boundary — proven

CAN THE AI ROLE...	RESULT
read the clinical view (ID + symptoms)	Yes – allowed
read the identity vault (name, email...)	No – denied
decrypt a civil ID	No – denied

Where: SQL Editor – has_table_privilege / has_function_privilege for role mediflow_agent.

One operator runs the clinic as **admin + reception** (two role rows in user_roles). These panels show real data — drop in matching Supabase screenshots for the final file if desired; the numbers will match.

What connects to what & next steps

The database is complete. These are the integration steps for the rest of the stack — no further database change needed.

Frontend (Vercel)

- Read the role-scoped views (doctor = ID-only).
- Approval screen + MFA sign-in for staff.
- Show the data-use disclaimer & transparency page.

n8n

- Connect the AI as the restricted role — not the master key.
- Gmail node sends confirmations + security alerts.

Gemini

- Prompt gets ID + symptoms only — no identity.
- Writes the visit summary back for the doctor.

Supabase config

- Enrol MFA for the operator.
- Set the AI role's password.

Priority: point n8n's AI at the restricted role (not the service key) — that single change makes the whole privacy design real end-to-end.